

Patch & Vulnerability Management Policy

Remediation timelines and scanning cadence (ID.RA, PR.PS)

Document ID: BVT-POL-036

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Purpose, Scope, and Authority

This policy is part of the BVTech Written Information Security Program, aligned to the NIST Cybersecurity Framework (CSF) 2.0. It applies to all BVTech LLC personnel, contractors, systems, and, where adopted by a client, the client's covered environment. The Managing Partner (or designated security officer) owns this policy, reviews it at least annually, and approves exceptions in writing. Violations may result in disciplinary action up to termination of employment or contract.

Exception process: submit written request describing the business need, compensating controls, and duration. Exceptions expire after 12 months unless renewed. NIST CSF 2.0 references shown per section (GV, ID, PR, DE, RS, RC).

Patching Cadence

Severity / Type	Target Deployment
Critical security updates (actively exploited / CISA KEV)	Within 72 hours of vendor release, emergency window if needed
High severity security updates	Within 7 days
Moderate/low security updates	Within 30 days (standard monthly window)
Feature updates / firmware	Tested, then scheduled windows; N-1 policy for major OS versions
Third-party applications (browsers, readers, runtimes)	Automated via RMM within 7 days

Process

- 1 RMM deploys approved patches during standing maintenance windows with reboot handling.
- 2 Failed patches generate tickets; devices failing twice are remediated manually within 5 business days.
- 3 Patch compliance is reported monthly; target $\geq 95\%$ of covered devices current within SLA.
- 4 Out-of-band emergency patching may occur for actively exploited vulnerabilities with best-effort client notice.

Vulnerability Management

- Vulnerability scanning at least monthly (authenticated where possible) across covered assets; external attack-surface review quarterly.
- Remediation SLAs: Critical 7 days, High 14 days, Medium 30 days, Low 90 days or risk-accept with documentation (BVT-SEC-021).
- End-of-life software/OS must be upgraded, isolated with compensating controls, or risk-accepted in writing.
- Findings, exceptions, and completion evidence are tracked in the vulnerability register.

